Practical 10

Password Security Assessment

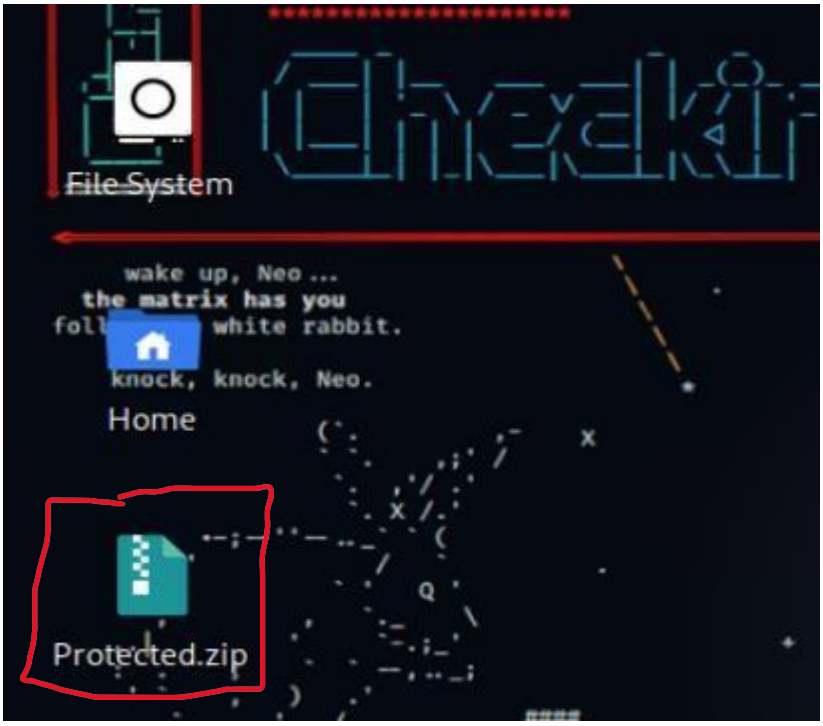
A. Password Cracking with John the Reaper

Theory: Password cracking with John the Ripper (often referred to simply as John) is a widely used open-source password cracking tool designed to uncover weak passwords by employing various attack techniques. John supports multiple password hash algorithms and can perform attacks like dictionary attacks, where it systematically tries words from a predefined list, and brute-force attacks, which systematically attempt all possible combinations. Additionally, John can utilize rainbow tables to accelerate the cracking process by precomputing hash values for common passwords. It is a powerful and flexible tool used by security professionals and penetration testers to assess the strength of passwords and enhance overall system security by identifying and mitigating potential vulnerabilities. However, it's important to note that using such tools for unauthorized access or without proper authorization is illegal and unethical.

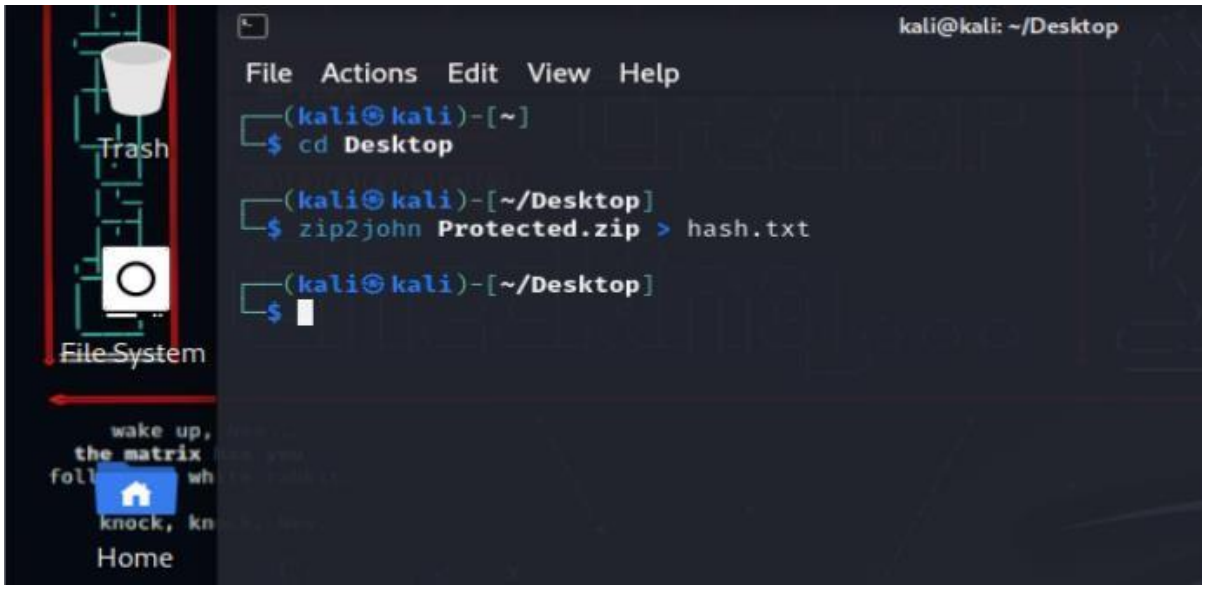
Step 1: Run John the Reaper tool in Kali Linux Using the command "john"

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ john
John the Ripper 1.9.0-jumbo-1+bleeding-aec1328d6c 2021-11-02 10:45:52 +0100 OMP [linux-gnu 64-bit x86_
64 AVX AC]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

Use --help to list all available options.

┌──(kali㉿kali)-[~]
└─$ john --help
John the Ripper 1.9.0-jumbo-1+bleeding-aec1328d6c 2021-11-02 10:45:52 +0100 OMP [linux-gnu 64-bit x86_
64 AVX AC]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

--help                      Print usage summary
--single[=SECTION[,..]]     "Single crack" mode, using default or named rules
--single=:rule[,..]         Same, using "immediate" rule(s)
--single-seed=WORD[,WORD]   Add static seed word(s) for all salts in single mode
--single-wordlist=FILE      *Short* wordlist with static seed words/morphemes
--single-user-seed=FILE     Wordlist with seeds per username (user:password[s]
                            format)
--single-pair-max=N         Override max. number of word pairs generated (6)
--no-single-pair            Disable single word pair generation
--[no-]single-retest-guess  Override config for SingleRetestGuess
--wordlist[=FILE] --stdin   Wordlist mode, read words from FILE or stdin
                  --pipe    like --stdin, but bulk reads, and allows rules
--rules[=SECTION[,..]]      Enable word mangling rules (for wordlist or PRINCE
                            modes), using default or named rules
--rules=:rule[;..]]         Same, using "immediate" rule(s)
--rules-stack=SECTION[,..]  Stacked rules, applied after regular rules or to
                            modes that otherwise don't support rules
--rules-stack=:rule[;..]    Same, using "immediate" rule(s)
--rules-skip-nop            Skip any NOP ":" rules (you already ran w/o rules)
```

Step 2: Create a file with password protected and save it in zip format.

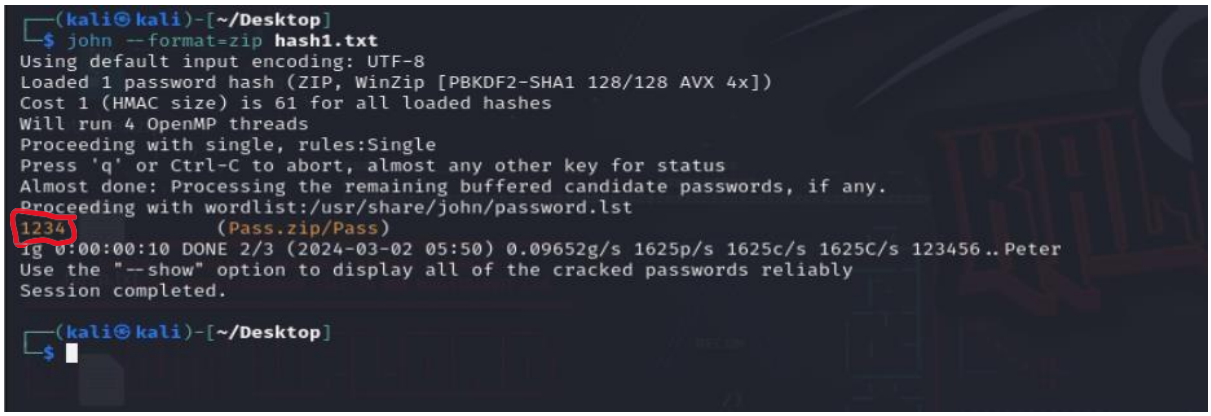


Step 3: Now convert the zip file to hash file and save it into another txt file using “zip2john Protected.zip (Name of your protected file) > hash.txt”



Step 4: Now to crack the password use the command “john –format=zip hash.txt (Name of your txt file which you have converted)”

Note: It can take few seconds and also more time as per the strength of the password eventually it can also take upto 12 Hrs.



B. Brute-Force Attack using Gobuster Tool.

Step1: Install Gobuster by simply typing “gobuster” in Kali Command line

```
kali@kali: ~/Desktop
File  Actions  Edit  View  Help

┌──(kali㉿kali)-[~/Desktop]
└─$ gobuster
Command 'gobuster' not found, but can be installed with:
sudo apt install gobuster
Do you want to install it? (N/y)y
sudo apt install gobuster
[sudo] password for kali:
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
Suggested packages:
  cupp
The following NEW packages will be installed:
  gobuster
0 upgraded, 1 newly installed, 0 to remove and 1501 not upgraded.
Need to get 2,538 kB of archives.
After this operation, 8,188 kB of additional disk space will be used.
Get:1 http://http.kali.org/kali kali-rolling/main amd64 gobuster amd64 3.6.0-1+b1 [2,538 kB]
Fetched 2,538 kB in 8s (324 kB/s)
Selecting previously unselected package gobuster.
(Reading database ... 399584 files and directories currently installed.)
Preparing to unpack .../gobuster_3.6.0-1+b1_amd64.deb ...
Unpacking gobuster (3.6.0-1+b1) ...
Setting up gobuster (3.6.0-1+b1) ...
Processing triggers for man-db (2.12.0-1) ...
Processing triggers for kali-menu (2023.4.6) ...

┌──(kali㉿kali)-[~/Desktop]
└─$
```

Step 2: Use the command “gobuster dir -u https://www.hackthebox.com/ (url of your target website) -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.txt (or any other file type or anything you are searching of)” and hit enter.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ gobuster dir -u https://www.hackthebox.com/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://www.hackthebox.com/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.php                 (Status: 403) [Size: 516]
/images               (Status: 301) [Size: 532] [--> http://www.hackthebox.com/images/]
/download.php         (Status: 403) [Size: 516]
/index.php            (Status: 200) [Size: 79003]
/2006.php             (Status: 403) [Size: 516]
/images.php           (Status: 403) [Size: 516]
/news.php             (Status: 403) [Size: 516]
/crack.php            (Status: 403) [Size: 516]
/warez.php            (Status: 403) [Size: 516]
/full.php             (Status: 403) [Size: 516]
/12.php               (Status: 403) [Size: 516]
/contact.php          (Status: 403) [Size: 516]
/about.php            (Status: 403) [Size: 516]
/search.php           (Status: 403) [Size: 516]
/spacer.php           (Status: 403) [Size: 516]
/privacy.php          (Status: 403) [Size: 516]
/11.php               (Status: 403) [Size: 516]
/serial.php           (Status: 403) [Size: 516]
/logo.php             (Status: 403) [Size: 516]
/blog.php             (Status: 403) [Size: 516]
/new.php              (Status: 403) [Size: 516]
/cgi-bin.php          (Status: 403) [Size: 516]
/faq.php              (Status: 403) [Size: 516]
/rss.php              (Status: 403) [Size: 516]
/10.php               (Status: 403) [Size: 516]
/home                 (Status: 302) [Size: 702] [--> https://www.hackthebox.com/login]
/home.php             (Status: 403) [Size: 516]
/rss                  (Status: 200) [Size: 42104]
/img.php              (Status: 403) [Size: 516]
/default.php          (Status: 403) [Size: 516]
```

Step 3: Now pick any one extension with the 200-status code and run it to confirm your attack.